Software Architecture and Design Specification

Online Exam Portal

Project: Online Exam Portal (Team 15)

Version: 3.0

Authors: Chiranthan V (PES2UG24CS138) · Dwijesh Krishna Ghattamaraju (PES2UG24CS163) · Harkirat Singh (PES2UG24CS180)

Date: 15-09-2026

Status: Final Submission

Derived from: Online_Exam_Portal_SRS_Final v1.0 , including its Requirements Traceability Matrix

Approvals

Role	Name	Signature / Date
Developer	Chiranthan V	
Developer	Dwijesh Krishna Ghattamaraju	
Developer	Harkirat Singh	
Course Instructor / Evaluator	Dr. Pradeep Kumar Kenny S	14_09_2026

1. Introduction

1.1 Purpose

This Software Architecture and Design (SAD) Specification defines the proposed technical architecture and detailed design of the Online Exam Portal, a web-based system that allows an Admin (faculty / exam coordinator) to build a reusable MCQ question bank and assemble, schedule, and manage timed exams, while Students attempt those exams under a server-enforced timer with automatic evaluation and reporting. This document translates the functional and non-functional requirements captured in the Software Requirements Specification (SRS v1.0) into a concrete architecture, module design, database schema, and API contract that guides implementation and forms the basis for the accompanying Software Test Plan.

This document is a design-phase artifact. It is written before/during implementation and describes the proposed system; it does not report on a completed or tested build.

1.2 Scope

This specification covers the architecture and design of Admin and Student web interactions: authentication and role-based access control (including login lockout and admin-initiated password reset), question-bank management with search/filter, exam creation/scheduling with batch assignment, timed exam attempts with auto-save and response locking, server-side auto-evaluation, gated result visibility, class/question-wise analytics reporting, bulk student import and batch management, tab-switch/blur/fullscreen-exit proctoring-lite logging with admin disqualify/re-permit, and email notifications. It excludes descriptive/subjective-question grading, live webcam proctoring, plagiarism detection, and integration with external university ERP or payment systems, consistent with the SRS scope (§1.2).

1.3 Audience

Developers (Team 15), course instructor/evaluators, and QA reviewers of this lab submission.

1.4 Definitions

MCQ (Multiple Choice Question), RBAC (Role-Based Access Control), JWT (JSON Web Token), NFR/FR (Non-Functional/Functional Requirement), RTM (Requirements Traceability Matrix), TLS (Transport Layer Security), CSV (Comma-Separated Values), WCAG (Web Content Accessibility Guidelines), ERD (Entity-Relationship Diagram), PK/FK (Primary Key/Foreign Key) — as defined in SRS §1.4.

2. Document Overview

2.1 How to use this document

This document provides the architectural and detailed-design deliverables for the Online Exam Portal: UML Component, Class and Sequence diagrams together with the Entity-Relationship Diagram (ERD), the chosen architecture pattern and rationale, the technology stack and data stores, the database design, the API design, the security architecture, and operational concerns (error handling, logging, monitoring, UX, and open issues). Section 3 (Architecture) covers structural and system-level decisions; Section 4 (Design) covers the detailed, module-level design built on top of that architecture. The design has been reconciled against the authoritative SRS PDF (Online_Exam_Portal_SRS_Final v1.0), particularly its System Models (§7), Database Design (§8), and Requirements Traceability Matrix (§9), with design-level implementation clarifications explicitly documented where required.

2.2 Related Documents

- Online_Exam_Portal_SRS_Final, v1.0 — authoritative source of requirements, entity model, and their IDs (SRS §9 Requirements Traceability Matrix)
- Software Test Plan (STP), v2.0 — companion document

- Test Cases & Requirements Traceability Matrix (RTM), v2.0 — companion workbook
- Coverage Report, v2.0 — companion document reconciling every requirement ID used across the SAD/STP/RTM against the SRS's own RTM (§9)

3. Architecture

The Online Exam Portal is a self-hosted three-tier web application consisting of a responsive browser client, an application tier exposing an HTTPS/JSON REST API and service/domain modules, and PostgreSQL as the system of record, with an optional Redis cache for session/timer state (SRS §2.1, §7.6). A data-access layer mediates persistence through the Django ORM. The system serves two roles — Admin and Student — through the same API surface, differentiated by RBAC. It integrates with exactly one external system: an SMTP service for email notifications, consistent with the SRS product perspective (a standalone system, not part of a larger LMS).

- Admin: authenticates → manages the question bank → creates and schedules an exam → attaches questions → assigns batches → monitors proctoring flags and disqualifies/re-permits attempts → reviews analytics/exports reports.
- Student: authenticates → views exams assigned to their batch(es) within the scheduled window → starts an attempt → answers questions under a live countdown with auto-save → submits (or is auto-submitted on timeout) → views the result once result_visible_from has passed.
- System (automated actor): server-side auto-submit on timeout, auto-evaluation of submitted responses, response locking after submission, and email notifications, all performed without client trust (SRS §7.4, §7.5).

3.1 Goals & Constraints

Goals:

- Security: the exam question bank and answer keys must never be exposed to a Student client, before or during an exam (OEP-F-007, OEP-SR-003).
- Integrity: once an attempt leaves IN_PROGRESS, no student or unauthorized party can alter its responses (OEP-F-018); every admin override is attributable via an audit log (OEP-SR-006).
- Reliability: resilient auto-save (≤10s apart, OEP-NF-004) and server-enforced timing so a browser refresh or brief network blip never costs the student their progress or extra time.
- Modularity: clear separation of concerns across the eight application-tier modules in SRS Figure 6, so each can be developed and tested independently.
- Maintainability and testability appropriate to a 3-person, one-semester student team; ≥70% automated unit-test coverage on core modules (OEP-NF-006).

Constraints:

- Must be deliverable within one academic semester by a 3-person student team (SRS §2.5).
- Modest infrastructure budget: a single VM or free-tier cloud instance is assumed for the demo deployment (SRS §2.5).
- Browser-based proctoring-lite cannot detect a second physical device; this is an explicit, accepted limitation stated in the SRS (§2.5).
- Client devices are modern evergreen browsers (Chrome, Firefox, Edge) on desktop and mobile; no specialized hardware is required (SRS §2.4, §3.2). The concrete frontend design uses React for the responsive web UI.

3.2 Stakeholders & Concerns

Stakeholder	Concern
Students	Fair, unambiguous timing; accurate, on-time results; simple, accessible UI

Stakeholder	Concern
Admin / Faculty	Efficient question-bank workflow; reliable scheduling; clear analytics; not treated as adversarial (SRS §2.3)
Course Instructor / Evaluators	Correctness, completeness, and traceability of the SE deliverables against the SRS
Developers (Team 15)	Modular, maintainable, testable codebase deliverable in one semester
Academic Integrity	Tamper-resistant scoring, proctoring-lite signals, disqualify/re-permit workflow, audit trail

3.3 Component (UML) Diagram

The structural/design diagrams below comprise the UML Component and Class diagrams together with the Entity-Relationship Diagram (ERD). The diagram source is preserved in Appendix D. The domain entities, fields and enumerations are aligned to the SRS Class Diagram (SRS Figure 3, §7.3) and Database Design (SRS §8), with implementation-level clarifications explicitly noted.

Component Diagram

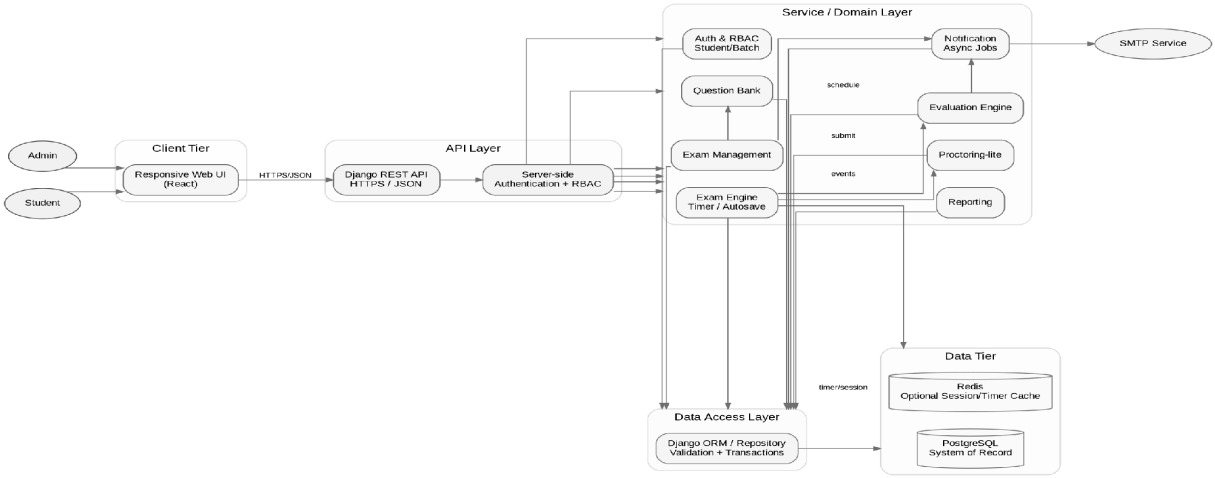


Figure 1. Component Diagram — client, API, service/domain, data-access and data tiers, with the eight application modules and external SMTP integration.

Class Diagram

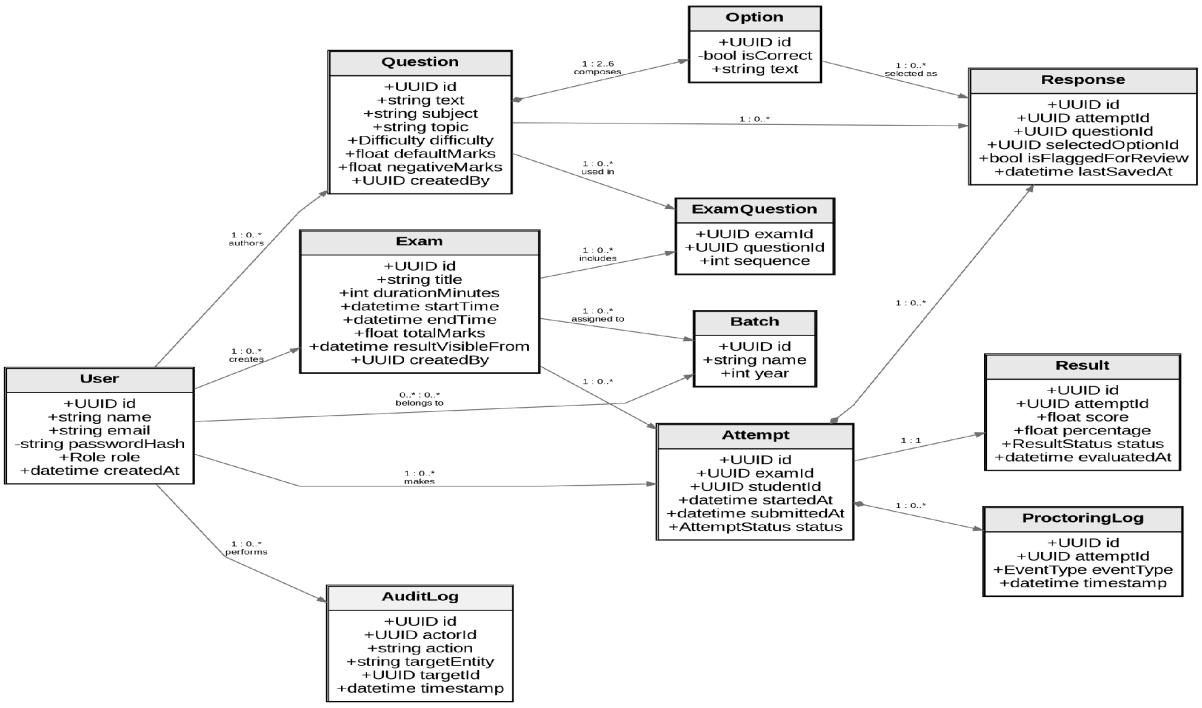


Figure 2. Class Diagram — domain model aligned with SRS Figure 3, using defaultMarks consistently in the design model and including the separate Result entity and AuditLog required by OEP-SR-006.

Entity-Relationship Diagram

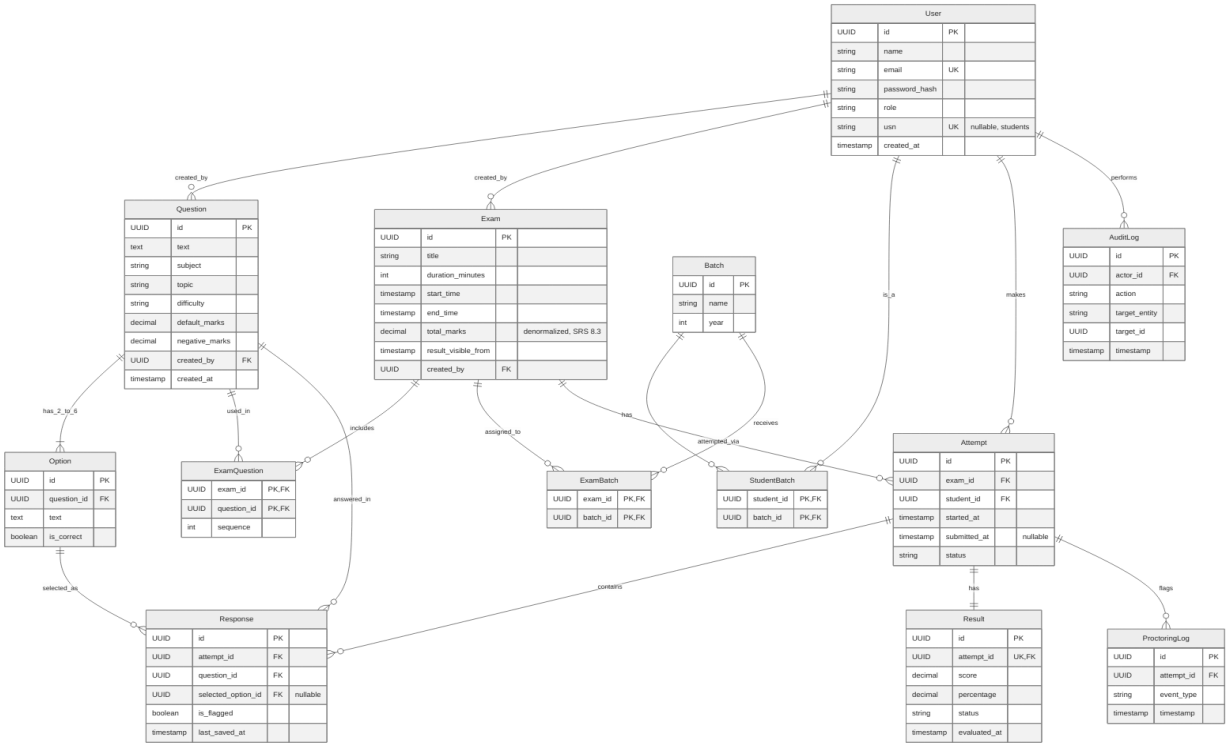


Figure 3. Entity-Relationship Diagram — full relational schema matching SRS §8.2 exactly.

Entity Summary:

PostgreSQL is the system of record, normalized to Third Normal Form (3NF) per SRS §8.3, with one documented, deliberate denormalization: exams.total_marks is a stored summary recomputed whenever exam_questions changes, since it is read far more often than it changes.

Note on AuditLog: this entity is required by OEP-SR-006 (“all Admin actions that alter question content, results, or attempt status…shall be written to an append-only audit log”) but is not separately itemized in the SRS's §8.1 Entities Overview list. It is included here as a necessary implementation entity to satisfy the verified OEP-SR-006 requirement.

Entity	Primary Key	Key Foreign Keys	Notes
User	id	—	role in {ADMIN, STUDENT}; password_hash salted/hashed (OEP-SR-001); usn nullable/unique for students
Batch	id	—	name, year (OEP-F-012)
StudentBatch	student_id + batch_id (composite PK)	student_id → User, batch_id → Batch	Resolves the Student–Batch many-to-many (OEP-F-012)
Question	id	created_by → User	subject, topic, difficulty {EASY,MEDIUM,HARD}, default_marks, negative_marks (OEP-F-005/006)
Option	id	question_id → Question	2–6 rows per Question, exactly one is_correct = true (OEP-F-005); is_correct never serialized to Student-facing endpoints (OEP-F-007/OEP-SR-003)
Exam	id	created_by → User	start_time, end_time, total_marks (denormalized), result_visible_from (OEP-F-008)
ExamQuestion	exam_id + question_id (composite PK)	exam_id → Exam, question_id → Question	sequence; recomputes Exam.total_marks (OEP-F-009)
ExamBatch	exam_id + batch_id (composite PK)	exam_id → Exam, batch_id → Batch	Defines which batches may attempt the exam (OEP-F-010)
Attempt	id	exam_id → Exam, student_id → User	UNIQUE(exam_id, student_id); status {IN_PROGRESS,SUBMITTED,AUTO_SUBMITTED,DISQUALIFIED} (OEP-F-014/OEP-SR-005)
Response	id	attempt_id → Attempt, question_id → Question, selected_option_id → Option (nullable)	is_flagged (review flag), last_saved_at; locked once Attempt leaves IN_PROGRESS (OEP-F-018)
Result	id	attempt_id → Attempt (UNIQUE)	score, percentage, status {PASS,FAIL}, evaluated_at (OEP-F-017); visible to student only once now ≥ exam.result_visible_from (OEP-F-008)

Entity	Primary Key	Key Foreign Keys	Notes
ProctoringLog	id	attempt_id → Attempt	event_type {TAB_SWITCH, BLUR, FULLSCREEN_EXIT} (OEP-F-020) — exact SRS terminology
AuditLog	id	actor_id → User	Append-only; required by OEP-SR-006; records disqualify/re-permit and other admin overrides

Key Constraints:

- CHECK on Option: between 2 and 6 rows per Question, with exactly one is_correct = true, enforced at the application layer (OEP-F-005 acceptance criteria: a question with zero or 2+ correct options is rejected on save).
- UNIQUE (exam_id, student_id) on Attempt — one attempt per student per exam, enforcing OEP-F-014 / OEP-SR-005 at the database level.
- UNIQUE (attempt_id) on Result — exactly one Result per Attempt.
- Once Attempt.status leaves IN_PROGRESS, all writes to that attempt's Response rows are rejected (OEP-F-018).
- CHECK (end_time > start_time) on Exam.
- Composite primary keys on StudentBatch, ExamQuestion, and ExamBatch (no surrogate id column), matching SRS §8.2 exactly.
- NOT NULL and foreign-key constraints enforce referential integrity across all join tables.
- Indexes: Attempt(exam_id, student_id) is indexed to support high-frequency attempt lookup and the one-attempt-per-student-per-exam constraint; Response(attempt_id, question_id) and relevant foreign-key columns are indexed for exam-session and reporting queries (OEP-NF-002).

3.4 Component Descriptions

- Auth & RBAC Module: authenticates Admin/Student, issues/refreshes JWTs, enforces RBAC server-side (OEP-F-001/003, OEP-SR-004), applies login lockout (OEP-F-002), handles admin password reset (OEP-F-004), and — per SRS Figure 6, which does not show a separate module for it — also owns student bulk import and batch management (OEP-F-011/012).
- Question Bank Module: CRUD for questions and their 2–6 Option rows, with subject/topic/difficulty search and filter (OEP-F-005/006); enforces answer-key confidentiality (OEP-F-007/OEP-SR-003).
- Exam Management Module: creates exams (incl. result_visible_from), attaches questions manually or by random tagged selection, and assigns batches (OEP-F-008/009/010).
- Exam Engine: enforces the server-timed attempt lifecycle within the scheduled window — start, autosave, submit/auto-submit, response locking, and proctoring-lite logging (OEP-F-013/014/015/016/018/020, OEP-SR-005). A server-side scheduler/worker evaluates expiry using stored start time plus duration and triggers auto-submit independently of client clock.
- Evaluation Engine: server-side auto-scoring with negative marking, writing a Result row (OEP-F-017).
- Reporting Module: gated result retrieval (respecting result_visible_from) and class/question-wise analytics with CSV/PDF export (OEP-F-019).
- Proctoring-lite Module: flagged-attempts view and admin disqualify/re-permit workflow, writing to AuditLog (OEP-F-020/021, OEP-SR-006).
- Notification Module: async email jobs for exam scheduling and result-visible events, queued within 1 minute (OEP-F-022).

3.5 Chosen Architecture Pattern and Rationale

A layered (n-tier) monolithic architecture is chosen: Presentation (React client) → Django REST API layer → Service/Domain layer (per-module business logic) → Data Access layer (Django ORM) → PostgreSQL. This separates concerns cleanly while remaining simple enough for a 3-person team to build, deploy, and test within one semester, and matches the module breakdown in SRS Figure 6 exactly.

A microservices architecture was considered and rejected: the expected load (a single department/institution, exam-time bursts rather than continuous high traffic) does not justify the operational overhead of independent services. A layered monolith with well-defined internal module boundaries gives most of the maintainability benefit of microservices — and a clear path to extract a service later (e.g., the Evaluation Engine) — without the deployment complexity.

Within the API layer, modules are organized by bounded responsibility so that the answer-key confidentiality requirement (OEP-F-007) can be enforced at a single, auditable boundary: only the Exam Engine and Evaluation Engine may read Option.is_correct, and no student-facing serializer includes it.

Key Design Decisions:

#	Decision	Rationale	Alternative Considered
ADR-1	Layered monolith over microservices	Fits team size/timeline; simpler deployment; matches SRS Figure 6's module breakdown directly	Microservices per module — rejected as premature
ADR-2	Server-authoritative exam timer	Prevents client-side time manipulation (OEP-F-016)	Client-only countdown — rejected, not tamper-resistant
ADR-3	JWT stateless authentication with protected refresh handling	Access-token authentication supports horizontal scaling; refresh tokens are protected in Secure, HttpOnly cookies.	Server-side session affinity — rejected to keep the API horizontally scalable.
ADR-4	Option as a separate entity (2–6 rows), not fixed option columns	Matches SRS Class Diagram and §8.2 exactly; supports a variable option count and clean is_correct exclusion per row	Fixed option_a–d columns — rejected, does not match SRS (which allows 2–6 options)
ADR-5	Separate Result entity (not fields on Attempt)	Matches SRS §8.2 exactly; keeps the attempt lifecycle record distinct from the scored outcome	Score/percentage fields on Attempt — rejected, contradicts the SRS schema
ADR-6	Student & batch management implemented inside the Auth & RBAC Module	SRS Figure 6 does not show a separate module box for OEP-F-011/012; folding it into Auth & RBAC avoids introducing an architectural component the SRS does not depict	Standalone Student & Batch Management module — rejected in this revision as an unnecessary architecture change

3.6 Technology Stack & Data Stores

Layer	Technology	Rationale
Frontend	React responsive web UI (desktop/mobile) with a persistent countdown-timer component	Provides the responsive exam interface required by SRS §3.1, including an always-visible timer, high-contrast mode and keyboard navigation.
Backend / API	Python 3.11, Django 4.x, Django REST Framework (primary recommendation per SRS cover page)	Batteries-included ORM, auth, and admin tooling suit a 1-semester build

Layer	Technology	Rationale
Authentication	JWT access + refresh tokens; Bearer access token; Secure/HttpOnly refresh cookie	Stateless API authentication supports RBAC and horizontal scale while protecting refresh-token state (OEP-F-001, OEP-SR-002/OEP-SR-004).
Database (data store)	PostgreSQL 14+	System of record; SRS-recommended store (§3.3, §8)
Cache / Session state (data store)	Redis (optional)	Exam-session/timer state and rate limiting, per SRS Figure 6
Email	SMTP via an institutional relay or SendGrid	Exam-scheduling and result-visible notifications (OEP-F-022)
Transport security	TLS 1.2+ on all connections; Secure + HttpOnly cookies where used	Enforced per OEP-SR-002.
Deployment	Docker containers on a single Linux VM	Fits the modest-infrastructure constraint (SRS §2.5)
Testing tools	Pytest / Django test client, Postman, Selenium, OWASP ZAP	Unit/API/UI/security testing (see companion Software Test Plan)

3.7 Risks & Mitigations

Risk	Mitigation
Single-VM deployment (modest-infrastructure constraint) could become a capacity/availability bottleneck	Containerized (Docker) deployment allows straightforward migration to a larger instance without redesign
Browser-based proctoring-lite cannot detect a second physical device (explicit, accepted SRS limitation, §2.5)	Documented as an accepted limitation; supplemented by the flagged-attempts admin review and disqualify/re-permit workflow (OEP-F-020/021), not relied on as a sole integrity control
3-person, one-semester team could run out of time for a more elaborate architecture	Layered monolith (§3.5) chosen specifically to reduce build/deployment complexity within the constraint
Client-reported exam timer could be manipulated to gain extra time	Timer is server-authoritative; auto-submit is server-triggered, independent of client action (OEP-F-016)
Result released before result_visible_from would undermine fairness across batches	Reporting Module gates GET result responses on now ≥ exam.result_visible_from (OEP-F-008)

3.8 Traceability to Requirements

The tables below list every requirement ID formally defined in the SRS's own Requirements Traceability Matrix (SRS §9), which in turn traces to SRS §4 (Functional), §5 (Non-Functional), and §5.1.2 (Security). All IDs below are formally defined in the SRS — none are marked unverified. Full per-requirement test-case and RTM mapping is in the companion Coverage Report and RTM workbook.

Functional Requirements (OEP-F-001 through OEP-F-022)

Req. ID	Requirement (per SRS §4)	SRS Section
OEP-F-001	Login with role-scoped session/JWT (Admin/Student)	4.1
OEP-F-002	Lock login after 5 consecutive failed attempts for 15 minutes; log the event	4.1

Req. ID	Requirement (per SRS §4)	SRS Section
OEP-F-003	Enforce RBAC at the API level (Student tokens cannot reach Admin-only endpoints)	4.1
OEP-F-004	Admin resets a student's password; forces re-verification via email (1-hour, single-use link)	4.1
OEP-F-005	Create/edit/delete MCQ questions: 2–6 options, exactly one correct, marks, negative marks, subject/topic/difficulty	4.2
OEP-F-006	Search/filter questions by subject, topic, and difficulty	4.2
OEP-F-007	Never expose a question's correct-option flag to any Student-facing API response	4.2
OEP-F-008	Create an exam with title, duration, total marks, start time, end time, result_visible_from	4.3
OEP-F-009	Attach questions to an exam manually or via random selection from tagged pools	4.3
OEP-F-010	Assign a scheduled exam to one or more student batches	4.3
OEP-F-011	Bulk-import students via CSV/Excel (name, email, USN, batch)	4.4
OEP-F-012	Create batches/sections and map students to them (many-to-many)	4.4
OEP-F-013	Show a Student only exams assigned to their batch(es) and within the scheduled window	4.5
OEP-F-014	Allow only one active attempt per (exam, student) pair	4.5
OEP-F-015	Auto-save the student's answer state to the server every 10 seconds	4.5
OEP-F-016	Auto-submit an attempt the instant the server-side timer reaches zero	4.5
OEP-F-017	Auto-evaluate a submitted attempt against stored correct Options, applying marks/negative-marking	4.6
OEP-F-018	Lock all Responses of an attempt from further modification once status leaves IN_PROGRESS	4.6
OEP-F-019	Generate class performance and question-wise difficulty reports, exportable to CSV/PDF	4.7
OEP-F-020	Log tab-switch/window-blur events per attempt; present a flagged-attempts view to Admin	4.7
OEP-F-021	Admin manually disqualifies or re-permits a flagged attempt, recorded in an audit log	4.7
OEP-F-022	Email notification to affected students when an exam is scheduled and when results become visible	4.7

Non-Functional Requirements (OEP-NF-001 through OEP-NF-006)

Req. ID	Requirement (per SRS §5)	Category
OEP-NF-001	Attempt page loads ≤ 2s; supports ≥200 concurrent students/exam with ≤95th-percentile 3s degradation	Performance
OEP-NF-002	Application tier horizontally scalable; DB indexed on (exam_id, student_id) for attempts/responses	Scalability

Req. ID	Requirement (per SRS §5)	Category
OEP-NF-003	99.5% availability during any published exam window (excluding pre-announced maintenance)	Reliability
OEP-NF-004	Auto-save at most 10 seconds apart; a crash loses no more than the last 10 seconds	Reliability
OEP-NF-005	Responsive UI, WCAG 2.1 AA basics (contrast, keyboard nav) for exam-taking screens	Usability/Accessibility
OEP-NF-006	≥70% automated unit-test coverage on core modules (evaluation engine, exam engine)	Maintainability

Security Requirements (OEP-SR-001 through OEP-SR-007)

Req. ID	Requirement (per SRS §5.1.2)	SRS Section
OEP-SR-001	Passwords stored using a salted one-way hash (bcrypt/Argon2); never stored/logged in plaintext	5.1.2
OEP-SR-002	All traffic over HTTPS/TLS 1.2+; session cookies marked HttpOnly and Secure	5.1.2
OEP-SR-003	Correct-option flag/answer key never in any Student-reachable API response; evaluation only server-side	5.1.2
OEP-SR-004	RBAC enforced on every API endpoint server-side, not only hidden in the UI	5.1.2
OEP-SR-005	Each attempt bound to a single active session; a second concurrent login for the same (exam, student) is rejected	5.1.2
OEP-SR-006	All admin actions altering question content, results, or attempt status written to an append-only audit log	5.1.2
OEP-SR-007	All user input validated and persisted via parameterized queries/ORM to prevent injection and stored XSS	5.1.2

3.9 Security Architecture

Authentication and Authorization

- Passwords are stored using a salted, adaptive one-way hash (bcrypt or Argon2); plaintext passwords are never logged or stored (OEP-SR-001).
- A login is locked for 15 minutes after 5 consecutive failed attempts, with the lockout event logged (OEP-F-002).
- Authentication uses stateless JWTs. The access token is presented as a Bearer token to protected API endpoints, while the refresh token is protected in a Secure, HttpOnly cookie. RBAC is enforced at the permission layer on every endpoint, not only in the UI (OEP-F-003, OEP-SR-004).
- Admin-initiated password reset issues a single-use link that expires after 1 hour and forces re-verification via email (OEP-F-004).

Answer-Key Confidentiality

Option.is_correct is excluded from every serializer reachable by a Student-scoped JWT, including the attempt-start and autosave responses. Only the Admin-facing question-bank serializer and the server-side Evaluation Engine (which never returns raw question data to the client) may read it. This directly satisfies OEP-F-007 / OEP-SR-003.

Attempt Integrity

- A unique constraint on Attempt (exam_id, student_id) prevents more than one attempt per (student, exam) pair — OEP-F-014 / OEP-SR-005.
- The exam timer is server-authoritative; the client-displayed countdown is advisory only, and autosave/submit calls are always re-validated against server time (OEP-F-016).
- Once Attempt.status leaves IN_PROGRESS, all Response writes for that attempt are rejected (OEP-F-018).
- Every admin disqualify/re-permit action, and any other admin override of question content, results, or attempt status, is written to the append-only AuditLog with actor, timestamp, and action (OEP-SR-006).

Transport and Infrastructure Security

- TLS 1.2+ is enforced on all connections; any authentication/session cookies used for refresh-token handling are marked HttpOnly and Secure (OEP-SR-002).
- All user-supplied input is validated and persisted via parameterized queries/ORM to prevent SQL/NoSQL injection and stored XSS in rendered question text (OEP-SR-007).

Threat Modeling (STRIDE)

Threat	Mitigation
Spoofing	JWT-based authentication; login lockout after 5 failed attempts (OEP-F-002)
Tampering	Server-authoritative timer and scoring; response locking post-submission; DB constraints; AuditLog
Repudiation	Append-only AuditLog with actor/timestamp on every admin action (OEP-SR-006)
Information Disclosure	Answer-key exclusion from student serializers (OEP-SR-003); TLS in transit (OEP-SR-002)
Denial of Service	Rate limiting; Redis-backed caching; horizontally scalable stateless API tier (OEP-NF-002)
Elevation of Privilege	Server-side RBAC checks on every endpoint, independent of client-side routing (OEP-SR-004)

4. Design

4.1 Design Overview

This section translates the architecture in Section 3 into concrete module-level behavior: the sequence of interactions for the two primary workflows (a student taking an exam, and an admin creating/scheduling one — matching SRS Figures 4 and 5), the full API contract each module exposes, and the operational concerns — error handling, logging, monitoring, UX, and open issues — that govern day-to-day behavior of the running system.

4.2 UML Sequence Diagrams

Two sequence diagrams cover the two primary flows specific to this project. The student flow explicitly validates batch assignment and the scheduled exam window before creating an attempt; the admin flow validates exam timing, question selection and batch assignment before scheduling notification.

Student Taking an Exam

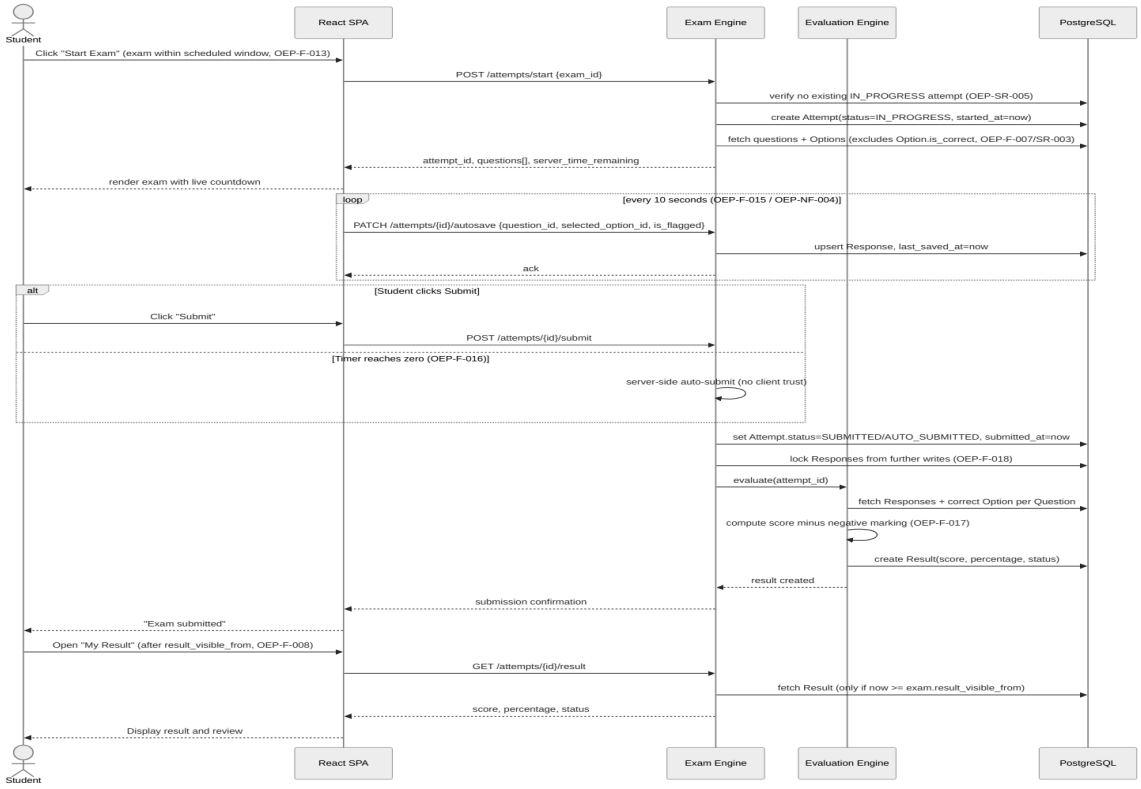


Figure 4. Sequence Diagram — Student Taking an Exam (assignment/window validation → start → autosave loop → submit/auto-submit → evaluation → gated result view).

Admin Creating and Scheduling an Exam

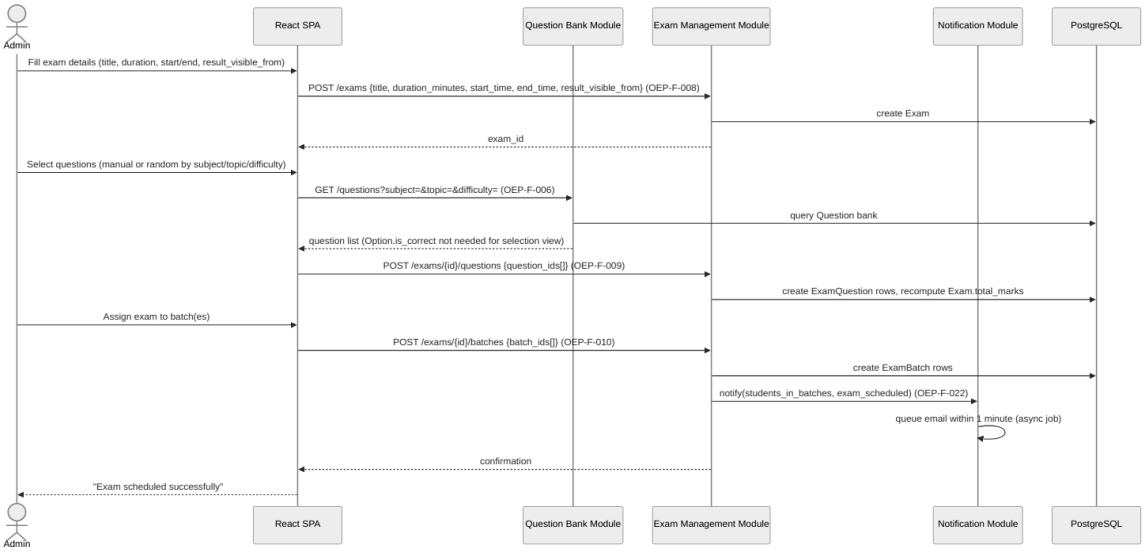


Figure 5. Sequence Diagram — Admin Creating and Scheduling an Exam (validation → create → attach questions → assign batches → notify).

4.3 API Design

All endpoints are namespaced under /api/v1, served over HTTPS/TLS 1.2+ (OEP-SR-002), and require a valid JWT bearer access token except where noted. Refresh-token handling uses a Secure, HttpOnly cookie. Role restrictions are enforced server-side (OEP-SR-004); a Student token can never read Option.is_correct (OEP-F-007 / OEP-SR-003).

Auth & RBAC Module — Authentication

Endpoint / Method	POST /api/v1/auth/login
Access	None
Purpose	Authenticate a user and issue tokens (OEP-F-001).
Request Body	`{ "email": "string", "password": "string" }`
Response Body	{ "access_token": "jwt", "role": "ADMIN|STUDENT", "user_id": "uuid" }
Status Codes	200 OK, 400 Bad Request, 401 Invalid Credentials, 423 Locked (6th consecutive failed attempt, OEP-F-002)
Validation Rules	email must be registered; password required; after 5 consecutive failed attempts the account is locked for 15 minutes and the event is logged (OEP-F-002)
Endpoint / Method	POST /api/v1/auth/refresh
Access	Secure, HttpOnly refresh cookie
Purpose	Exchange a valid refresh token for a new access token.
Request Body	None (refresh token supplied by Secure, HttpOnly cookie)
Response Body	{ "access_token": "jwt" }
Status Codes	200 OK, 401 Invalid/Expired Refresh Token
Validation Rules	refresh cookie must contain a well-formed, unexpired, non-blacklisted refresh token
Endpoint / Method	POST /api/v1/auth/students/{id}/reset-password
Access	Admin
Purpose	Admin resets a student's password and forces re-verification via email (OEP-F-004).
Request Body	`None (id in path)`
Response Body	`{ "reset_link_sent": true, "expires_at": "timestamp" }`
Status Codes	200 OK, 403 Forbidden, 404 Not Found
Validation Rules	Reset link expires 1 hour after issue and is valid for a single use (OEP-F-004 acceptance criteria)

Auth & RBAC Module — Student & Batch Management

Endpoint / Method	POST /api/v1/students/bulk-import
Access	Admin
Purpose	Bulk-create Student accounts from a CSV/Excel roster (OEP-F-011).
Request Body	`multipart/form-data: file=roster.(csv|xlsx) (columns: name, email, usn, batch)`
Response Body	`{ "created": 42, "errors": [ {"row": 7, "reason": "duplicate email"} ] }`
Status Codes	201 Created, 207 Multi-Status (partial), 400 Invalid File, 403 Forbidden
Validation Rules	Valid rows create accounts; invalid rows are reported with reasons, not silently dropped (OEP-F-011 acceptance criteria)

Endpoint / Method	POST /api/v1/batches
Access	Admin
Purpose	Create a batch/section (OEP-F-012).
Request Body	`{ "name":"string", "year":2026 }`
Response Body	`{ "id":"uuid" }`
Status Codes	201 Created, 400 Validation Error, 403 Forbidden
Validation Rules	name and year required
Endpoint / Method	POST /api/v1/batches/{id}/students
Access	Admin
Purpose	Map one or more students to a batch, many-to-many (OEP-F-012).
Request Body	`{ "student_ids": ["uuid"] }`
Response Body	`{ "batch_id":"uuid", "mapped": 30 }`
Status Codes	200 OK, 400 Validation Error, 403 Forbidden
Validation Rules	A student may belong to more than one batch (OEP-F-012 acceptance criteria)

Question Bank Module

Endpoint / Method	GET /api/v1/questions
Access	Admin
Purpose	Search/filter questions in the bank by subject, topic, and difficulty (OEP-F-006).
Request Body	`Query params: ?subject=&topic=&difficulty=&page=`
Response Body	{ "count": 120, "results": [{"id":"uuid","text":"...","subject":"DBMS","topic":"Normalization","difficulty":"MEDIUM","default_marks":1.0,"options":[{"id":"uuid","text":"...","isCorrect":true}, "..."]}] }
Status Codes	200 OK, 403 Forbidden
Validation Rules	Filter returns only matching questions (OEP-F-006 acceptance criteria); Option.isCorrect is included only for Admin-role responses
Endpoint / Method	POST /api/v1/questions
Access	Admin
Purpose	Create a new question with 2–6 Option rows (OEP-F-005).
Request Body	{ "text":"string","subject":"string","topic":"string","difficulty":"EASY|MEDIUM|HARD","default_marks":1.0,"negative_marks":0.25,"options":[{"text":"string","is_correct":true}, "... (2 to 6 total)"] }
Response Body	`{ "id": "uuid" }`
Status Codes	201 Created, 400 Validation Error, 403 Forbidden
Validation Rules	Between 2 and 6 options required; exactly one option must have is_correct=true — zero or 2+ correct options is rejected on save (OEP-F-005 acceptance criteria)

Endpoint / Method	PUT /api/v1/questions/{id}
Access	Admin
Purpose	Update an existing question and/or its options.
Request Body	`Same body as POST`
Response Body	`{ "id": "uuid" }`
Status Codes	200 OK, 400 Validation Error, 403 Forbidden, 404 Not Found
Validation Rules	Same 2–6-option / exactly-one-correct rule as create
Endpoint / Method	DELETE /api/v1/questions/{id}
Access	Admin
Purpose	Delete a question and its options.
Request Body	None
Response Body	`{ "id": "uuid", "deleted": true }`
Status Codes	204 No Content, 403 Forbidden, 404 Not Found, 409 Conflict (question in use)
Validation Rules	A question referenced by any ExamQuestion cannot be deleted

Exam Management Module

Endpoint / Method	POST /api/v1/exams
Access	Admin
Purpose	Create a new exam (OEP-F-008).
Request Body	`{ "title":"string","duration_minutes":60,"start_time":"ISO-8601","end_time":"ISO-8601","result_visible_from":"ISO-8601" }`
Response Body	`{ "id":"uuid","total_marks":0.0 }`
Status Codes	201 Created, 400 Validation Error, 403 Forbidden
Validation Rules	end_time > start_time; all fields validated on save (OEP-F-008 acceptance criteria)
Endpoint / Method	POST /api/v1/exams/{id}/questions
Access	Admin
Purpose	Attach questions to an exam, manually or by random selection from tagged pools (OEP-F-009).
Request Body	`{ "mode":"manual|random", "question_ids":["uuid"], "random_count":10, "subject":"string", "topic":"string", "difficulty_mix":{"EASY":3,"MEDIUM":5,"HARD":2} }`
Response Body	`{ "exam_id":"uuid","question_count":10,"total_marks":10.0 }`
Status Codes	200 OK, 400 Validation Error, 403 Forbidden, 404 Exam Not Found
Validation Rules	Random selection respects the requested count and difficulty mix (OEP-F-009 acceptance criteria); recomputes Exam.total_marks
Endpoint / Method	POST /api/v1/exams/{id}/batches

Access	Admin
Purpose	Assign a scheduled exam to one or more student batches (OEP-F-010).
Request Body	`{ "batch_ids":["uuid"] }`
Response Body	`{ "exam_id":"uuid","batches_assigned":2 }`
Status Codes	200 OK, 400 Validation Error, 403 Forbidden
Validation Rules	Only students in an assigned batch can see the exam (OEP-F-010 acceptance criteria)

Exam Engine (Student-facing)

Endpoint / Method	GET /api/v1/exams/available
Access	Student
Purpose	List exams assigned to the student's batch(es) and currently within the scheduled window (OEP-F-013).
Request Body	None
Response Body	`{ "results": [ {"exam_id":"uuid","title":"string","start_time":"...","end_time":"...","duration_minutes":60} ] }`
Status Codes	200 OK
Validation Rules	An exam outside the window is not listed/accessible (OEP-F-013 acceptance criteria)
Endpoint / Method	POST /api/v1/attempts/start
Access	Student
Purpose	Start an exam attempt.
Request Body	`{ "exam_id": "uuid" }`
Response Body	`{ "attempt_id":"uuid","questions":[{"id":"uuid","text":"...","options":[{"id":"uuid","text":"..."}, "... (2-6)"]}],"server_time_remaining_seconds":3600 }`
Status Codes	201 Created, 403 Forbidden (not in assigned batch or outside window), 409 Conflict (second concurrent attempt)
Validation Rules	Second login for the same (exam, student) pair while IN_PROGRESS is rejected (OEP-F-014/OEP-SR-005); response never includes Option.is_correct (OEP-F-007/OEP-SR-003)
Endpoint / Method	PATCH /api/v1/attempts/{id}/autosave
Access	Student (attempt owner)
Purpose	Persist the student's current selection for one question, called at most every 10 seconds (OEP-F-015/OEP-NF-004).
Request Body	`{ "question_id":"uuid","selected_option_id":"uuid|null","is_flagged":false }`
Response Body	`{ "acknowledged": true, "server_time_remaining_seconds": 3554 }`
Status Codes	200 OK, 403 Forbidden, 409 Conflict (attempt not IN_PROGRESS)

Validation Rules	Refreshing mid-exam restores the last auto-saved answers (OEP-F-015 acceptance criteria); rejected once Attempt leaves IN_PROGRESS (OEP-F-018)
Endpoint / Method	POST /api/v1/attempts/{id}/submit
Access	Student (attempt owner) or System (auto-submit)
Purpose	Finalize the attempt, lock its Responses, and trigger evaluation.
Request Body	`None (system auto-submit uses an internal service token, not a student JWT)`
Response Body	`{ "attempt_id":"uuid","status":"SUBMITTED" }`
Status Codes	200 OK, 403 Forbidden, 409 Conflict (already submitted)
Validation Rules	Status becomes AUTO_SUBMITTED at timer expiry even if the tab is inactive (OEP-F-016); Responses are locked from further modification the instant status leaves IN_PROGRESS (OEP-F-018)
Endpoint / Method	POST /api/v1/attempts/{id}/proctoring-log
Access	Student (attempt owner)
Purpose	Log a proctoring-lite signal during an active attempt (OEP-F-020).
Request Body	`{ "event_type":"TAB_SWITCH|BLUR|FULLSCREEN_EXIT" }`
Response Body	`{ "logged": true }`
Status Codes	201 Created, 403 Forbidden, 409 Conflict (attempt not IN_PROGRESS)
Validation Rules	event_type must be exactly one of TAB_SWITCH, BLUR, or FULLSCREEN_EXIT — the exact SRS §7.3/§8.2 enumeration

Proctoring-lite Module (Admin-facing)

Endpoint / Method	GET /api/v1/attempts/flagged
Access	Admin
Purpose	Present a flagged-attempts view for admin review (OEP-F-020).
Request Body	`Query params: ?exam_id=`
Response Body	`{ "results": [ {"attempt_id":"uuid","student":"...","event_counts":{"TAB_SWITCH": 2,"BLUR":1,"FULLSCREEN_EXIT":0}} ] }`
Status Codes	200 OK, 403 Forbidden
Validation Rules	Two tab switches during an attempt create two ProctoringLog rows visible to Admin (OEP-F-020 acceptance criteria)
Endpoint / Method	POST /api/v1/attempts/{id}/disqualify
Access	Admin
Purpose	Manually disqualify a flagged attempt (OEP-F-021).
Request Body	`{ "reason": "string" }`
Response Body	`{ "attempt_id":"uuid","status":"DISQUALIFIED" }`
Status Codes	200 OK, 403 Forbidden, 404 Not Found

Validation Rules	A disqualified attempt is excluded from results/reports until re-permitted (OEP-F-021 acceptance criteria); action written to AuditLog (OEP-SR-006)
Endpoint / Method	POST /api/v1/attempts/{id}/re-permit
Access	Admin
Purpose	Reverse a disqualification (OEP-F-021).
Request Body	None
Response Body	`{ "attempt_id":"uuid","status":"SUBMITTED" }`
Status Codes	200 OK, 403 Forbidden, 404 Not Found, 409 Conflict (not currently disqualified)
Validation Rules	Action written to AuditLog with actor, timestamp, and action (OEP-SR-006)

Reporting Module

Endpoint / Method	GET /api/v1/attempts/{id}/result
Access	Student (own attempt) or Admin
Purpose	Retrieve the result for a specific attempt, gated by result visibility (OEP-F-008).
Request Body	None
Response Body	`{ "attempt_id":"uuid","score":8.5,"percentage":85.0,"status":"PASS", "evaluated_at":"timestamp" }`
Status Codes	200 OK, 403 Forbidden, 404 Not Found, 425 Too Early (before exam.result_visible_from, Student role only)
Validation Rules	A Student may only fetch their own attempt, and only once now ≥ exam.result_visible_from; Admin may fetch any attempt for their exams at any time
Endpoint / Method	GET /api/v1/reports/exams/{exam_id}
Access	Admin
Purpose	Class performance and question-wise difficulty report, exportable to CSV/PDF (OEP-F-019).
Request Body	`Query params: ?format=json|csv|pdf`
Response Body	`{ "exam_id":"uuid","attempted":48,"average_score":7.2,"question_stats":[{"question_id":"uuid","correct_pct":63.5}] }`
Status Codes	200 OK, 403 Forbidden, 404 Not Found
Validation Rules	Export file matches on-screen report totals (OEP-F-019 acceptance criteria)

Notification Module: exam-scheduled and result-visible emails are sent by an internal async job (OEP-F-022), not by a client-facing REST endpoint; the job is triggered by the Exam Management Module (on batch assignment) and the Evaluation/Reporting path (when now reaches exam.result_visible_from), and is queued within 1 minute of the triggering action (OEP-F-022 acceptance criteria).

4.4 Error Handling, Logging & Monitoring

Error Handling

- All API errors return a consistent JSON envelope: { "error": { "code": "string", "message": "string", "details": {} } } with an appropriate HTTP status code.

- Validation errors (400) enumerate every failing field; authorization failures (403) never reveal whether a resource exists to an unauthorized caller.
- Autosave requests use short-timeout retries with exponential backoff so a brief network blip does not fail the attempt (SRS §3.4).

Logging

- Application logs (structured JSON) capture request id, user id, endpoint, status code, and latency — never passwords, tokens, or answer keys.
- Security and operational events are recorded in structured application logs. Administrative state-changing actions required by OEP-SR-006 — including question-content changes, result changes, and attempt-status overrides — are additionally persisted in the append-only AuditLog with actor, timestamp and action.

Monitoring

- Uptime/availability monitoring against the 99.5% target during scheduled exam windows (OEP-NF-003).
- Latency and error-rate dashboards for the attempt-start, autosave, and submit endpoints, sized to the 200-concurrent-student / 2s-load / 3s-p95 target (OEP-NF-001).
- Alerting on autosave failure-rate spikes and on any unexpected drop in active-attempt count during a scheduled window (possible outage indicator).

4.5 UX Design

The exam-attempt screen keeps the countdown timer persistently visible (SRS §3.1). The UI is responsive across desktop and mobile-browser viewports and meets WCAG 2.1 AA basics — contrast and keyboard navigation — for exam-taking screens (OEP-NF-005). Question navigation clearly distinguishes answered, unanswered, and flagged-for-review questions (Response.is_flagged).

4.6 Open Issues & Next Steps

Open design notes:

- AuditLog is included at the design level because OEP-SR-006 explicitly requires an append-only audit log containing actor, timestamp and action. It is therefore treated as a necessary implementation entity even though it is not separately listed in SRS §8.1.
- The physical design uses default_marks consistently for the question-level stored mark value, following the SRS §8.2 database definition. The functional requirement wording in the traceability table continues to use the SRS's original term "marks".

Future Enhancements (beyond current SRS scope):

- Descriptive/subjective question support with rubric-assisted grading (explicitly excluded by SRS §1.2).
- Live webcam proctoring and automated plagiarism/similarity detection (explicitly excluded by SRS §1.2).
- Integration with an institutional ERP for roster sync (explicitly excluded by SRS §1.2).

5. Appendices

Appendix A: Glossary

See Section 1.4 (Definitions).

Appendix B: References

- Online_Exam_Portal_SRS_Final, v1.0 (authoritative source PDF) — System Models §7, Database Design §8, Requirements Traceability Matrix §9
- IEEE 42010 — Systems and software engineering — Architecture description

- OWASP Top 10 — Web Application Security Risks

Appendix C: Tools

- Mermaid (diagram source, Appendix D) — used for sequence-diagram source and semantic diagram specification; structural figures are rendered using equivalent offline diagram tooling.
- Postman (API design/testing) — see companion Software Test Plan
- draw.io (supplementary diagram editing, if needed)